

Les pièges de ce projet

Tout ce qui a mordu, ou qui a failli. Chaque entrée dit le piège, ce qu'il produit, et la parade retenue.

À quoi ça sert. La plupart de ces pièges ne se voient pas à la relecture du code : ils se manifestent en conditions réelles, souvent en silence, et quelques-uns auraient rendu le boîtier inutilisable un jour de tournage. Les consigner évite de les redécouvrir.

Les plus coûteux sont marqués . Ce sont ceux qui échouent SANS MESSAGE : ce sont toujours les pires, parce qu'on cherche au mauvais endroit.

1. Le boîtier et son système

Un chemin entre guillemets dans une unité systemd

`WorkingDirectory="$PROJECT_DIR"` : systemd **ne retire pas les guillemets** dans ce réglage. Il reçoit un chemin qu'il juge non absolu et refuse toute l'unité, avec un message que personne ne peut interpréter : *bad unit file setting*. Passait sur Bookworm, refusé sur trixie. **Parade** : pas de guillemets. Les `Exec*`, eux, les acceptent.

`set -e` qui coupe sur un message incompréhensible

Quand le service refusait de démarrer, le script d'installation s'arrêtait net — et **le WiFi, le pare-feu et le kiosque n'étaient jamais configurés**. L'utilisateur ne voyait qu'une ligne obscure. **Parade** : afficher `systemctl status` et `journalctl` avant de sortir.

XAUTHORITY manquant : une fenêtre qui ne s'ouvre jamais, sans erreur

Un programme graphique lancé depuis un service systemd est **refusé par le serveur graphique** si cet en-tête d'autorisation manque. `DISPLAY` seul ne suffit pas. Rien ne s'affiche, rien ne le dit. **Parade** : résoudre `XAUTHORITY` en même temps que `DISPLAY`.

Le chemin du fichier PID dérivé de l'environnement

La session graphique et le service systemd n'ont pas le même `HOME` ni le même `XDG_RUNTIME_DIR`. Un chemin construit à partir de l'un donne **deux fichiers différents**, donc un état faux en permanence.

Parade : un chemin fixe, `/tmp/prompteur-kiosk-<uid>.pid`.

`PrivateTmp=yes` casse ce partage

Excellent réglage de sécurité en général — **ici il isole le service dans son propre** `/tmp`, et il perd de vue le navigateur du kiosque. **Parade** : tout le durcissement systemd, sauf celui-là, et le dire en commentaire.

Scripts enregistrés en mode 644 alors qu'on fait `chmod +x`

La procédure fait `chmod +x install/setup.sh`. Git voit ce changement de permission comme une modification locale, et **bloque tout** `git pull` ultérieur. **Parade** : enregistrer les scripts en 755 dans le dépôt.

Fins de ligne CRLF sur un fichier `.sh`

Un script écrit depuis Windows avec des fins de ligne CRLF échoue sur le Pi avec *bad interpreter*. Les outils d'édition le font sans prévenir. **Parade** : `.gitattributes` force LF, et on vérifie après chaque écriture automatisée.

`su` dans un script qui tourne déjà sous le bon utilisateur

Ajouté pour lire le dossier du bureau : `su` **réclame un mot de passe** et bloque l'installation sur une invite que personne n'attend. **Parade** : ne pas changer d'utilisateur quand on est déjà le bon.

Le dossier du bureau ne s'appelle pas « Desktop »

Sur un système en français, c'est « **Bureau** ». **Parade** : `xdg-user-dir DESKTOP`, avec repli sur les deux noms.

raspi-config change de présentation

Les versions récentes scindent « Boot / Auto Login » en **deux lignes distinctes**. N'en faire qu'une laisse le boîtier sur un écran de connexion, et le prompteur ne démarre jamais seul. **Parade** : documenter les deux présentations, et dire que les deux réglages sont nécessaires.

Le pilote d'écran fourni par le vendeur

Le script `LCD35C-show` **désactive le pilote graphique** `vc4-kms-v3d` — sur un Pi 5 il n'y a aucun mode de secours derrière — et **force le HDMI en 480×320**, écrasant le grand écran. Il est conçu pour une machine à un seul écran. **Parade** : ne pas le lancer. Déclarer l'écran en mode DRM, à la main.

Les réglages `hdmi_*` sont ignorés sur Pi 5

Presque tous les tutoriels en ligne datent d'avant le changement d'architecture graphique. Les recettes qu'on trouve **ne font rien**, sans le dire.

2. Le logiciel

Un texte trop gros fige l'écran, et le gel survit au redémarrage

Aucune borne sur la taille. Un `.docx` de 35 Ko dont le XML se décompresse en 8,9 Mo donnait **7,7 Mo de texte et 40 000 lignes** ; l'affichage crée un élément par ligne. Et comme le texte est enregistré, **l'écran restait figé à chaque démarrage** : seule sortie, un clavier et un terminal. Ce n'est pas qu'une attaque : un PDF de catalogue importé par erreur fait pareil. **Parade** : borner la taille décompressée avant de lire, puis le texte, puis tronquer au chargement — le boîtier doit redémarrer, même dégradé.

Le confinement réseau ne protège pas du navigateur

Le pare-feu limite le port au WiFi du boîtier. Mais une page web piégée ouverte sur un téléphone **déjà connecté à ce WiFi** peut viser le boîtier sans la moindre interaction : la requête part de l'intérieur du périmètre. **Parade** : contrôle de l'origine, `application/json` exigé, en-tête maison sur l'envoi de fichier.

Un GET qui modifie l'état

`/api/library/load` répondait en GET tout en changeant le texte à l'antenne : une simple balise `<img>` suffisait. **Parade** : toute route qui modifie quelque chose est en POST.

Jinja ne recharge pas les gabarits hors mode debug

Un `git pull` qui change une page **n'a aucun effet** tant que le service n'est pas redémarré. On croit la mise à jour ratée. **Parade** : `sudo systemctl restart prompteur` fait partie de la procédure, en gras.

La politique de sécurité interdit les scripts écrits dans la page

Ajouter une CSP `script-src 'self'` casse instantanément tout `<script>` inline — ici celui qui indiquait le mode de l'écran. **Parade** : passer la donnée par un attribut `data-`. Un attribut est une donnée, pas du code.

Un réglage refusé qui passe pour appliqué

Le serveur répondait « ok » même quand rien n'avait été accepté. Le bouton se colorait, on croyait avoir changé de mode, **rien n'avait bougé**. **Parade** : répondre 400 en nommant les clés refusées, et relire l'état réel.

Chaque appui sur Lecture renvoyait tout le script

La commande faisait avancer la version générale, ce qui obligeait chaque écran à retélécharger l'intégralité du texte — plusieurs mégaoctets sur le WiFi, à chaque bouton, au pire moment. **Parade** : ne faire avancer la version que quand un réglage change réellement.

Un `state.json` écrit sans synchronisation

Le renommage est atomique, mais les données peuvent n'être pas encore sur la carte lors d'une coupure. Le fichier tronqué est alors **écarté en silence** : le journaliste rallume et retrouve le texte de bienvenue, sans explication. **Parade** : `flush` + `fsync` avant de renommer.

Un verrou sans expiration condamne l'appareil

Réserver « l'écran principal » à un seul appareil est nécessaire. Mais un verrou qu'on oublie de rendre — onglet fermé brutalement, WiFi coupé — **interdirait à tout le monde de lire**, soit l'inverse du but. **Parade** : un bail qui expire seul, et une reprise en main toujours offerte.

Une suppression sans recours

La croix effaçait un texte sans confirmation, sans corbeille, sans sauvegarde, et le dossier des textes n'est pas versionné. **Parade** : confirmation, et l'échec est dit au lieu d'être avalé.

3. L'interface

Le plein écran est refusé sans geste de l'utilisateur

Un navigateur **refuse toujours** le plein écran demandé au chargement. La fonction semble cassée alors qu'elle est simplement interdite à ce moment-là. **Parade** : l'installer au premier geste venu ; et ouvrir l'écran principal dans une fenêtre dédiée, ce qui donne le geste.

En plein écran, Échap appartient au navigateur

Il s'en sert pour sortir du plein écran : le gestionnaire de la page **ne la voit jamais**. **Parade** : écouter la sortie de plein écran et la traiter comme la demande de quitter.

Un bouton prend le focus au clic, et la sélection disparaît

Appliquer un style au texte sélectionné échoue dans certains navigateurs, parce que le bouton a vidé la sélection avant même le clic. **Parade** : `mousedown` + `preventDefault` : le bouton ne prend pas le focus.

`window.close()` n'est autorisé que sur une fenêtre ouverte par script

Une page ordinaire ne peut pas se fermer elle-même. **Parade** : ouvrir l'écran de lecture par `window.open`, ce qui autorise ensuite à le refermer — et évite la navigation, donc l'impasse.

Quitter vers une page morte, sans flèche retour

En kiosque il n'y a **ni barre d'adresse ni bouton retour**. Si le service est tombé, revenir à l'accueil mène à une page d'erreur sans aucun moyen d'en sortir. **Parade** : refuser de quitter tant que la liaison est perdue, et l'expliquer.

Reconstruire la zone de saisie à chaque frappe

Cela replace le curseur au début à chaque caractère. **Parade** : recalculer les données sans reconstruire ; le rendu suit au prochain geste explicite.

Une fonction complète et pourtant inutilisable

La mise en forme s'appliquait correctement, mais **rien ne le montrait** — une zone de saisie ordinaire ne sait pas afficher du gras. On concluait que le bouton ne faisait rien. **Parade** : montrer le résultat là où l'on agit. C'est ce qui a conduit à remplacer la zone de saisie par une zone éditable riche.

Un bouton désactivé qui n'en a pas l'air

« Ouvrir » restait vert vif alors qu'il ne faisait rien : on le presse en boucle. **Parade** : styliser l'état désactivé.

Deux écrans principaux se disputent le défilement

Chacun pousse sa position : le texte saute d'un endroit à l'autre en pleine lecture. **Parade** : un seul meneur à la fois, le bouton se grise, la reprise reste possible.

4. Les données et les formats

Des indices calculés avant nettoyage sont faux après

La mise en forme d'un document Word se lit sur le XML brut, mais elle doit désigner le texte **après** nettoyage — or le nettoyage change les longueurs. Une plage décalée de trois signes **met en évidence les mauvais mots** en pleine lecture : c'est pire que pas de mise en forme du tout. **Parade** : un nettoyage qui note, pour chaque caractère survivant, d'où il vient. La table est produite pendant le nettoyage, jamais reconstituée après coup.

Un nettoyage est contextuel, pas local

Découper d'abord puis nettoyer chaque morceau donne un texte **différent** : deux espaces à cheval sur une frontière ne se voient plus. **Parade** : un seul algorithme de nettoyage, pour tous les cas.

Stocker du HTML pour de la mise en forme

Tenant, et c'est le piège : il faut alors se fier à un échappement partout, et un ancien fichier devient ambigu. **Parade** : le texte reste une chaîne brute, la mise en forme est une liste de plages posées dessus. Rien à échapper, et les anciens textes s'affichent inchangés.

Une syntaxe de type markdown changerait les textes existants

Un `*` ou un `#` au milieu d'une phrase déjà enregistrée se mettrait soudain à signifier quelque chose.

5. L'outillage et la vérification

Filtrer l'affichage d'un contrôle masque son échec

`bandit` sort en erreur **dès la moindre alerte, même de sévérité faible**. En filtrant l'affichage sur « High » et « Medium », la ligne fautive n'apparaissait jamais : la CI est restée rouge **six commits d'affilée** pendant qu'on annonçait « tout est vert ». **Parade** : ce qui compte est le **code de sortie**, pas ce qu'on choisit d'afficher. `scripts/verifier-ci.sh` rejoue toutes les étapes sans filtre.

Un faux positif vaut mieux corrigé que muselé

`bandit` voyait un mot de passe en dur dans une clé de dictionnaire nommée `token`. **Parade** : renommer la clé. Un `nosec` aurait éteint le contrôle pour de bon.

Un outil qui analyse une liste de fichiers n'analyse pas le projet

Un nouveau module n'aurait jamais été examiné. **Parade** : analyser le dossier, avec des exclusions.

Ce qu'aucune règle n'interdit finira par arriver

Rien n'empêchait d'écrire du HTML depuis le JavaScript — le garde-fou qui manquait le plus une fois le contenu mis en forme introduit. **Parade** : l'interdire dans la CI. Un oubli ne se voit pas à la relecture ; il se voit à la CI.

Un banc d'essai qui ment

Le volet de prévisualisation interne **bloque l'API plein écran et supprime les fenêtres popup**. Trois fonctions correctes ont semblé cassées, et il a fallu un essai dans un vrai navigateur pour trancher.

Parade : faire vérifier dans un vrai navigateur ce qui touche au plein écran, aux fenêtres et aux permissions.

Les outils d'édition automatisée abîment les échappements

Écrire du code par script en passant par un shell mange les `\n` et les antislashes, ce qui produit des fichiers corrompus, parfois subtilement. **Parade** : écrire les fichiers directement, et relire le résultat.

Un remplacement global finit par toucher ce qu'il ne fallait pas

Remplacer un appel partout a réécrit l'intérieur de la fonction qui le remplaçait : **réursion infinie**.

Parade : vérifier ce qu'on vient de remplacer, pas seulement que ça compile.

6. L'usage, le jour du tournage

Le mot de passe WiFi n'est affiché qu'une fois

Généré au hasard à l'installation, il n'existe nulle part ailleurs. **Parade** : l'imposer soi-même à l'installation, et le noter sur la fiche du boîtier.

Relancer l'installation recrée le WiFi

Sans redonner le mot de passe actuel, un nouveau est tiré au hasard et **plus aucun téléphone ne se connecte**.

Pas d'internet une fois connecté au boîtier

C'est voulu. Mais le script doit donc **déjà être sur le téléphone** : on ne peut plus aller le chercher dans ses mails à ce moment-là. C'est ce qui bloque le plus sûrement un premier tournage.

Le logiciel du pédalier ne tourne que sous Windows

Parade : l'apprentissage des touches dans l'application, qui ne demande aucun PC.

Une touche de pédale peut rendre la pédale muette

F est prise par le plein écran, Échap par le retour à l'accueil, et deux pédales sur la même touche s'annulent. **Parade** : les refuser à l'apprentissage, et prévenir pour les autres raccourcis.

Un écran noir et muet

Quand la liaison est perdue, l'écran ne montrait rien et ne disait rien : personne ne pouvait savoir si le texte affiché était encore d'actualité. **Parade** : un bandeau qui dit ce qui compte — le texte reste lisible, les pédales fonctionnent.

Ce qu'on en retient

1. **Ce qui échoue en silence coûte le plus cher**. Sur les vingt pièges les plus coûteux de ce projet, la quasi-totalité ne produisait aucun message.

2. **Un garde-fou qui peut enfermer dehors est pire que pas de garde-fou.** Verrou sans expiration, sortie vers une page morte, bouton totalement inerte.
3. **Une fonction qu'on ne voit pas agir est réputée cassée**, même quand elle fonctionne.
4. **Vérifier, c'est regarder le code de sortie**, pas la sortie qu'on a choisi d'afficher.
5. **Le banc d'essai fait partie des sources d'erreur.** Quand un résultat surprend, suspecter l'outil de mesure autant que le code.